

Phase 5.2.3 Token Revocation & Logout Report

Appliance Target: RCS CyberTrack Core Management | Status: 100% PASSED (130/130 Tests)

EXECUTIVE SUMMARY:

Phase 5.2.3 Token Revocation & Logout has been successfully implemented across RCS CyberTrack's security infrastructure. A persistent database revocation model (RevokedTokenDB) tracks unique token JTIs. The POST /api/v1/auth/logout endpoint enables secure, idempotent user logout with audit logging. API authorization checks verify JTI revocation status post-cryptographic verification. The full test suite passed with **130 passed tests** (10 new dedicated Phase 5.2.3 token revocation tests).

1. Implemented Revocation Architecture

- **Persistent Revocation Model (`RevokedTokenDB`):** Added revoked_tokens database table storing unique JTI, user ID, username, revocation timestamp, expiration, and reason.
- **Authenticated Logout Endpoint:** Added POST /api/v1/auth/logout endpoint allowing authenticated users to invalidate active tokens safely.
- **JTI Revocation Enforcement:** Updated get_current_user(...) to check is_token_revoked(db, jti) post-cryptographic verification, rejecting revoked tokens with HTTP 401 Unauthorized.
- **Idempotent Logout & Token Isolation:** Handled repeated logout requests safely without database duplication or errors. Guaranteed that revoking one token does not affect other active tokens for the user.
- **Expired Revocation Record Cleanup:** Implemented cleanup_expired_revoked_tokens(db) to purge obsolete revocation entries where expires_at < utc_now().
- **Audit Logging & Secret Non-Exposure:** Logs LOGOUT events with username, JTI, reason, and client IP. Never exposes raw tokens, secrets, or authorization headers.

2. Test Verification Results

Test Suite Module	Status	Test Scope / Coverage
test_api.py	PASSED	API authentication, system status & RBAC rules
test_firewall.py	PASSED	Firewall rule management & compilation
test_network.py	PASSED	Network interface & routing engine
test_phase4b_api.py	PASSED	Security alert & audit log endpoints
test_phase51_rbac_users.py	PASSED	User management & lockout safeguards
test_phase52_config_engine.py	PASSED	Configuration staging & commit state machine
test_phase53_nftables.py	PASSED	nftables compiler & process isolation
test_phase54_hardening.py	PASSED	Phase 5.1 production security boundaries
test_phase521_secret_bootstrap.py	PASSED	Phase 5.2.1 secret & bootstrap hardening
test_phase522_jwt_security.py	PASSED	Phase 5.2.2 JWT claims, algorithm lock & verification
test_phase523_token_revocation.py	PASSED	Phase 5.2.3 JTI revocation model, logout & cleanup
TOTAL SUITE RESULT	130 PASSED	100% Pass Rate (130 Passed in 16.31s)

3. Modified Repository Files Manifest

File Path	Status	Description of Changes
management/database/models.py	Modified	Added RevokedTokenDB model & revoked_tokens table
management/auth/auth.py	Modified	Implemented is_token_revoked, revoke_token, & cleanup
management/api/server.py	Modified	Implemented POST /api/v1/auth/logout endpoint
tests/test_phase523_token_revocation.py	CREATED	10 new revocation, logout & cleanup tests

4. Verification Conclusion

Phase 5.2.3 Token Revocation & Logout is complete, verified, and regression-free. The authentication and token lifecycle system meets all security standards.